00后黑客落网！曾运营大型僵尸网络，频繁攻击腾讯游戏、DeepSeek、X平台

原创 腾讯程序员 腾讯技术工程 2025年9月22日 02:35 广东 398人



据美国司法部通报，活跃多年的高危DDoS僵尸网络“RapperBot”（历史频繁攻击腾讯游戏、DeepSeek、X平台的幕后黑手）现已被成功取缔。该僵尸网络主谋、22岁的美国俄勒冈州男子Ethan Faulds已于2025年8月6日被搜查住所，其基础设施控制权被执法部门依法接管，目前他面临协助及教唆计算机入侵罪的指控，最高可判处10年监禁。这一消息与腾讯宙斯盾情报系统监测到RapperBot僵尸网络活跃度数据吻合。Ethan Faulds于6号被捕后，7日该僵尸网络活跃度直接清零，其攻击趋势如下图所示。



一、RapperBot僵尸网络家族回顾

1.1 家族简介

RapperBot最早于2021年5月开始活动，主要通过暴力破解攻击入侵数字视频录像机（DVR）、Wi-Fi路由器等物联网设备，组建僵尸网络并发动大规模分布式拒绝服务（DDoS）攻击。该恶意软件技术继承自fBot和Mirai家族，具备高度破坏性和隐蔽性。

该僵尸网络规模一度达到6.5万–9.5万台受控设备，发动超过37万次DDoS攻击，影响了包括中国、日本、美国、爱尔兰和香港在内的18,000名受害者，单次攻击峰值流量据称超过6 Tbps。除DDoS外，该网络还被用于门罗币加密货币劫持和勒索型DDoS攻击（RDoS）。

1.2 样本分析

RapperBot新变种主要通过SSH爆破，漏洞利用等方式进行传播，入侵成功后在目标设备植入僵尸木马程序，随后连接C2并根据C2下发的攻击指令对目标发起DDoS攻击。以x86版本样本garm5为例进行分析，样本基本信息如下：

文件名	garm5
md5	487dd999e01599f9a14d9083b2983ef8
文件大小	64.66k
文件类型	ELF 32-bit
处理器架构	386-32

bot运行后会在终端输出标志性的字符串"Firmware update in progress"，并删除自身。



接着利用STUN协议获取肉鸡公网IP地址和端口信息，解析OpenNIC域名iranistrash.libre获取C2 IP，与C2建立连接。然后发送上线包，上线信息包括机器名称，样本运行位置等。发送和接收数据均经过加密处理，需要与数据种指定字节进行异或来解密。收到上线请求后，服务器端会返回两个数据包，第二个数据包种带有攻击指令。

对收到数据进行异或运算后的值对应各攻击参数示意：

其中第12字节0x05，代表命令类型为执行DDoS攻击；

第13,14字节0x0001代表攻击类型为upd_flood;

第8,9字节0x004B代表攻击时长 75秒；

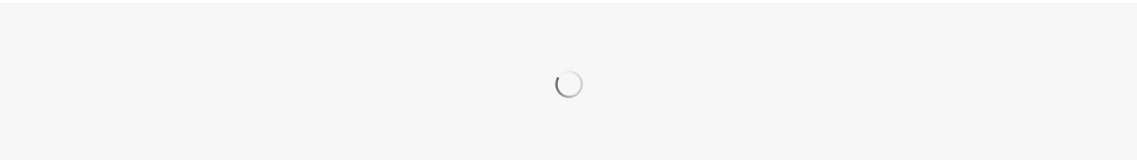
第10,11,12,13个字节代表攻击IP 5...37；

第14字节0x20代表子网掩码32；

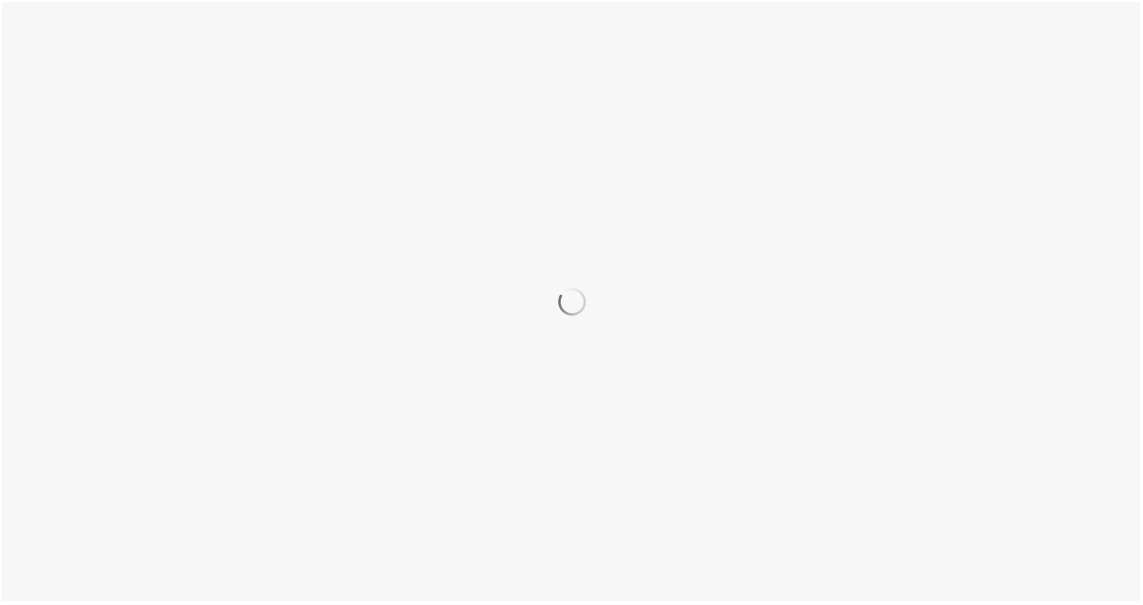
第15字节0x00代表选项类型是payload长度；

第16字节0x04代表通过4个字节的ASCII显示payload长度；

随后的4个字节0x31343030代表payload长度为1400(对于ASCII码)。



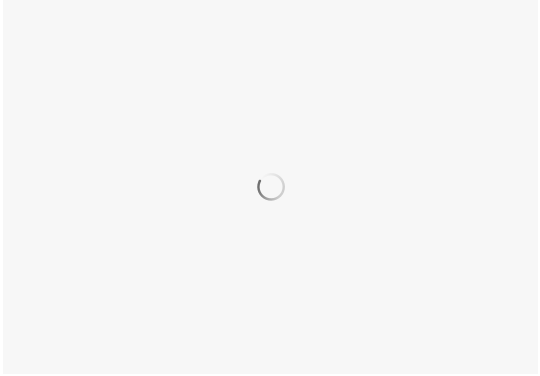
僵尸样本按照该指令发出的DDoS攻击包为：



1.3 攻击手段

RapperBot的攻击手法随着技术迭代变得愈发刁钻：

● **“组合拳”介绍：**指令不再只控制一种攻击手法，部分指令由单一攻击手法升级为多种手法混合攻击。特别是TCP连接型攻击明显增多，攻击时肉鸡与目标建立大量真实的TCP连接，然后循环利用每个连接发送数据包，防护难度飙升。



● **“地图炮”成主流：**RapperBot按照网段进行攻击的指令上升明显，通过设置攻击时的子网掩码为24/23/22/21/17/16/12等，将单条指令的攻击范围扩大到整个网段。近期捕获到RapperBot攻击子网网段的DDoS手法有7种，其中udp_connect_flood手法进行网段攻击的指令有297条，按照子网掩码24进行计算，仅这个攻击手法通过扫段可以覆盖的攻击范围就多达297*254=75438个IP，极大拓宽了攻击的威胁范围。

1.4 典型攻击案例

- **2025年春节期间，针对deepseek发起大规模DDoS攻击**
- **2025年2.28日-3.11日期间针对马斯克的X平台(twitter)发起了3波攻击**
- **2025年3.23-3.24 针对暴雪服务器发起多轮DDoS攻击**
- **2025年暑期针对腾讯游戏业务的批量DDoS攻击**

二、DDoS僵尸网络背后的盈利模式

2.1 黑产链条

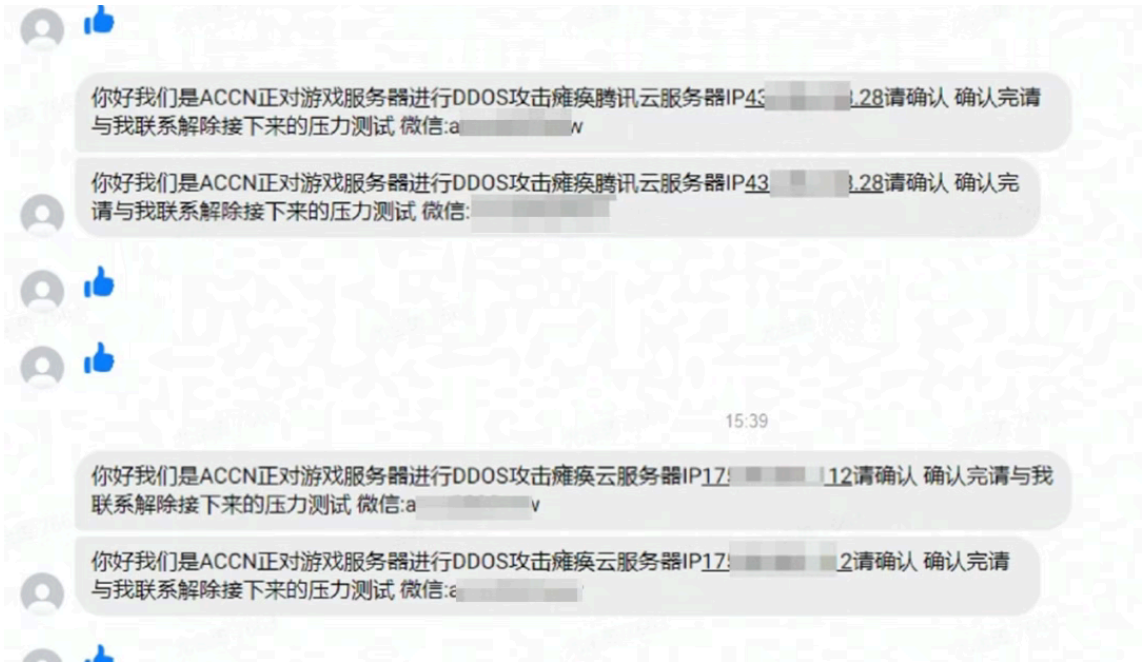
攻击者通过DDoS攻击迫使目标支付赎金以恢复服务，常见于金融、游戏、电商等行业。近期高发的“攻击前预警勒索”模式中，威胁行为者会先发出勒索信，如未付款即发动实际攻击。

2.2 盈利渠道

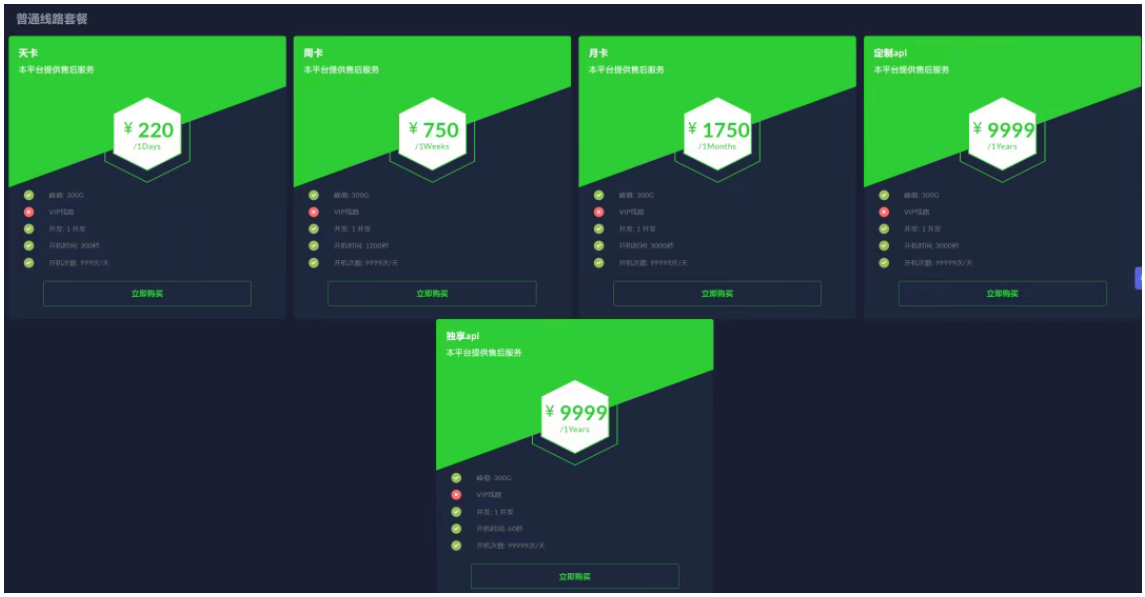
- 租赁服务。当前主要的盈利模式，攻击团伙将控制的僵尸网络（肉鸡）作为攻击资源出租给其他犯罪分子


ddos 攻击
3.6K subscribers
Pinned Message
. 套餐档位 600G----4T...
22 2
1.5K 11:33
. L4
全球UDP 700-1000G
国内 Syn 150-200G
冷却60s 100次/天/70u
支持付费测试 开卡免费测试
479 13:01
May 14
套餐档位
600G----4T
100u/天 800-1t
188u/天 2.7T
300u/天4T
仅支持非正规目标压力测试
仅限于非政企目标压力测试
@
70 66 55 43 41
16
3.7K edited 15:24
pinned ". 套餐档..."
May 16
出售cc和tcp 有需要的联系我 支持测试
重要说三遍 是机器人机器人机器人攻击

● 敲诈勒索。直接向目标企业或网站发起DDoS攻击威胁，并以此索要“保护费”以停止攻击。其中游戏行业中ACCN组织便已是臭名昭著（弈剑行开服当天因DDoS勒索被迫关服），自然腾讯自研游戏以及腾讯云上外部游戏商被勒索案例也是层出不穷。



● 售卖攻击资源与攻击服务。将僵尸网络对应攻击能力封装成攻击页端或者api形式，对外按照次数或者时间维度进行售卖。



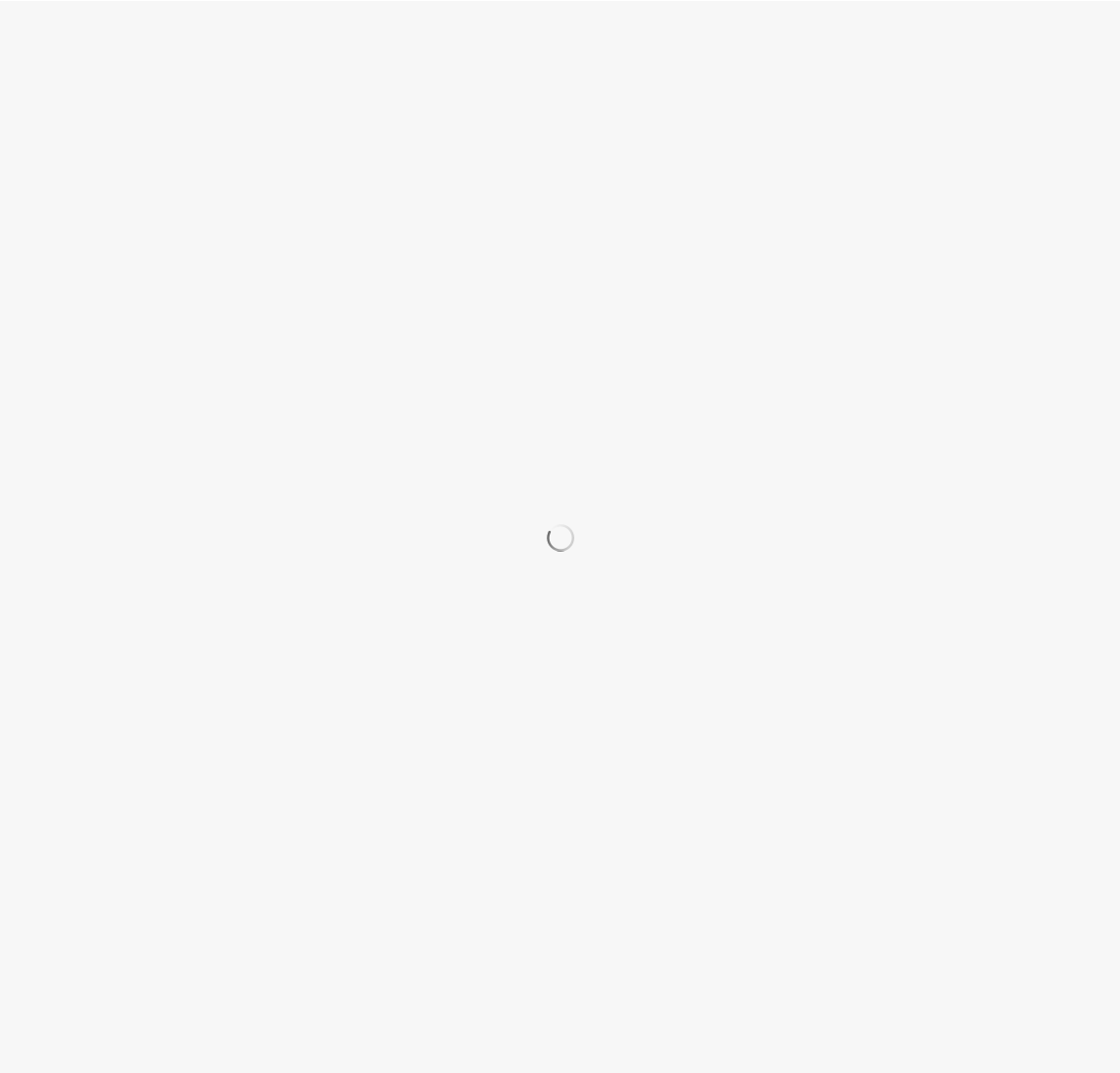


● 多元化利用僵尸网络资源。例如广告点击欺诈、针对特定游戏的DDoS炸房功能，并以此获取对应收益

三、腾讯宙斯盾情报系统简介

3.1 系统架构介绍

我们的DDoS情报收集主要基于我们自研的蜜罐，同时也会对外部开源的情报渠道进行监控互补。整个自研蜜罐的架构如图:



技术上我们开发了一个高交互、高仿真、全端口开放并响应的的蜜罐，并在全球多地部署捕获DDoS攻击者的样本。为了能及时监控僵尸网络的最新动向，我们将捕获到的最新样本置入养鸡场中，通过对样本与C2进行通信的流量进行实时分析，提取出黑产团伙下发的攻击指令信息。

3.2 AI助力样本分析提效

在DDoS情报获取的关键环节——僵尸网络样本分析过程中，我们结合了大模型能力进行提效。利用大模型接口对样本反编译后代码进行推理分析，通过MCP方式调用调试器提高样本动态调试效率，并且通过大模型对样本的家族特征进行分析。得益于多种场景下的大模型助力，僵尸网络样本核心解密逻辑代码逆向效率上提升80%，样本家族分类也实现了90%自动化，为DDoS情报的威胁发现、态势感知和联动防护等应用提供了有力支持。

四、 DDoS安全防护建议

4.1避免沦为“肉鸡”

强化设备级安全，杜绝僵尸节点植入。排查并更换默认密码与弱口令设备，关闭非必要服务（如Telnet、SSH公网暴露），及时修补已知漏洞。建议部署IoT设备准入控制与微隔离策略，限制横向移动。

4.2 自动化灾备调度能力建设

鸡蛋放在多个篮子里，业务在面对极端对抗场景或者平台级攻击场景下，能够基于自动化灾备调度能力降低业务影响的同时，提高攻击方攻击成本。

4.3 定期DDoS蓝军演练主动排雷

制定演练计划以及应急联合处置流程。明确不同攻击规模下、不同影响情况下的处置流程（灾备切换、异常机器屏蔽等）。通过定期开展红蓝对抗与恢复演练，提升实战应对能力。

五、结束语

僵尸网络不死，DDoS对抗不休！每一次攻击都在警示：“没有安全的爆款，只有爆款的安全”。安平宙斯盾致力于守护每一局游戏畅玩、每一次用户的丝滑体验！



腾讯技术工程
腾讯技术官方号。腾讯技术创新、前沿领域发布解读平台。
690篇原创内容
公众号



阅读 2.9万

留言

写留言

还没有留言，来写首评